

Checklist

Cloud Infrastructure Security

Cloud Service Models

- ☐ Understand the differences between **SaaS, PaaS, and IaaS**.
- ☐ Identify what the **cloud provider** secures for each service model.
- ☐ Identify what the **customer** is responsible for securing.
- ☐ Review the **shared responsibility model** for AWS, Azure, and GCP.
- ☐ Remember: the provider generally secures the cloud infrastructure, while you secure your data, identities, configurations, and workloads.

Prevent Misconfigurations

- ☐ Regularly audit cloud configurations.
- ☐ Use automated configuration-monitoring tools.
- ☐ Enable tools such as **AWS Config, Azure Policy/Defender for Cloud, or Google Security Command Center**.
- ☐ Follow the **principle of least privilege**.
- ☐ Avoid overly permissive IAM roles, storage permissions, and firewall rules.
- ☐ Use **Infrastructure as Code (IaC)** where possible.
- ☐ Store IaC in source control.
- ☐ Require code review before infrastructure changes are deployed.
- ☐ Add security checks to CI/CD pipelines.

Credentials and Secrets

- ☐ Enforce strong password policies.
- ☐ Use a password manager or secure password vault.
- ☐ Enable **MFA**, especially for root and administrator accounts.
- ☐ Extend MFA to all user accounts where possible.

- ☐ Remove access immediately when employees or contractors leave.
- ☐ Use centralized identity management and SSO when possible.
- ☐ Never hardcode passwords, API keys, tokens, or other secrets in source code.
- ☐ Scan repositories for exposed secrets.
- ☐ Store secrets in a dedicated secrets-management service.
- ☐ Rotate secrets regularly.
- ☐ Establish a process for responding to exposed credentials.

IAM and Permissions

- ☐ Grant users and services only the permissions required for their jobs.
- ☐ Regularly review user, group, service, and role permissions.
- ☐ Remove unused or excessive privileges.
- ☐ Use **role-based access control (RBAC)**.
- ☐ Scope roles according to job function.
- ☐ Monitor privileged permission changes.
- ☐ Alert on unexpected or unauthorized privilege escalation.

Security Hygiene

- ☐ Maintain an inventory of cloud assets.
- ☐ Patch systems and applications regularly.
- ☐ Continuously scan for vulnerabilities.
- ☐ Back up critical data.
- ☐ Test backup restoration procedures.
- ☐ Maintain a disaster recovery plan.
- ☐ Encrypt sensitive data.
- ☐ Secure network boundaries with firewalls, VPNs, and appropriate access controls.
- ☐ Collect and retain security logs.
- ☐ Monitor logs for suspicious behavior.
- ☐ Use recognized security frameworks such as **CIS Controls** or **NIST CSF**.

Secure Architecture

- ☐ Use established architecture patterns instead of designing everything from scratch.
- ☐ Separate application layers in a **three-tier architecture** where appropriate.

- ☐ Segment networks so internal tiers are not directly exposed to the internet.
- ☐ Apply strict network ACLs and security groups.
- ☐ Consider **microservices** when independent scaling and isolation are beneficial.
- ☐ Secure communication between microservices.
- ☐ Review dependencies and inherited risks in microservice environments.
- ☐ Consider **event-driven architecture** when appropriate.
- ☐ Apply security controls to event producers, consumers, and channels.
- ☐ Use provider reference architectures as a starting point.

Well-Architected Frameworks

- ☐ Review the **AWS Well-Architected Framework**.
- ☐ Review the **Microsoft Azure Well-Architected Framework**.
- ☐ Review the **Google Cloud Architecture Framework**.
- ☐ Evaluate security alongside reliability, performance, operations, and cost.
- ☐ Reassess architecture as workloads and threats change.

Security Visibility and Monitoring

- ☐ Enable visibility into the overall security posture.
- ☐ Monitor cloud environments for threats and vulnerabilities.
- ☐ Configure alerts for important security events.
- ☐ Centralize logs and alerts in a SIEM when possible.
- ☐ Create incident-response procedures for cloud security events.
- ☐ Test security alerts before relying on them in production.

AWS GuardDuty Exercise

Configure SNS Email Notifications

- ☐ Sign in to the **Amazon SNS console**.
- ☐ Select **Topics**.
- ☐ Choose **Create topic**.
- ☐ Select **Standard** as the topic type.
- ☐ Name the topic `Guard_Duty_Notification`.
- ☐ Create the topic.
- ☐ Open **Subscriptions**.
- ☐ Choose **Create subscription**.

- ☐ Select the `GuardDutyNotification` topic ARN.
- ☐ Select **Email** as the protocol.
- ☐ Enter the email address that should receive alerts.
- ☐ Create the subscription.
- ☐ Open the confirmation email.
- ☐ Confirm the SNS subscription.

Enable GuardDuty

- ☐ Open the **AWS Management Console**.
- ☐ Navigate to **GuardDuty**.
- ☐ Enable GuardDuty if it is not already enabled.
- ☐ Review the permissions GuardDuty requires.
- ☐ Open **Settings**.
- ☐ Set the finding export/update frequency to approximately **15 minutes** if following the exercise.

Configure EventBridge

- ☐ Open the **Amazon EventBridge console**.
- ☐ Select **Rules**.
- ☐ Choose **Create rule**.
- ☐ Name the rule `GuardDutyFinding`.
- ☐ Use the **default event bus**.
- ☐ Enable the rule.
- ☐ Select **Rule with an event pattern**.
- ☐ Set the event source to **AWS services**.
- ☐ Select **GuardDuty** as the AWS service.
- ☐ Select **GuardDuty Finding** as the event type.
- ☐ Verify the event pattern includes `aws.guardduty`.
- ☐ Continue to **Target selection**.
- ☐ Select **AWS service** as the target type.
- ☐ Select **SNS topic** as the target.
- ☐ Choose `GuardDutyNotification`.
- ☐ Review the configuration.
- ☐ Create the EventBridge rule.

Validate the Configuration

- ☐ Return to the GuardDuty console.
- ☐ Navigate to **Settings**.
- ☐ Find **Sample findings**.
- ☐ Select **Generate sample findings**.
- ☐ Verify that sample GuardDuty findings appear.
- ☐ Check that notification emails are received.
- ☐ Open individual findings and review severity, affected resources, region, and timestamps.
- ☐ Confirm that the SNS/EventBridge notification workflow operates as expected.

Final Security Review

- ☐ Understand the shared responsibility model.
- ☐ Secure the cloud perimeter.
- ☐ Monitor continuously for misconfigurations.
- ☐ Use IAM securely.
- ☐ Maintain visibility into the security posture.
- ☐ Enforce cloud security policies.
- ☐ Encrypt sensitive data.
- ☐ Keep the security team trained on evolving cloud threats.
- ☐ Maintain logs and monitor for threats and vulnerabilities.
- ☐ Treat compliance as a baseline—not the end of the security program.